Module 1: Fundamentals of Information Security

1.Motivation:

Computer security attempts to ensure the confidentiality, integrity, and availability of computing systems' components. These areas of a computing system are subject to attacks: hardware, software, and data. These three, the communications among them, and the personal involved constitute the basis of computer security vulnerabilities. In turn, those people and systems interested in compromising a system can devise attacks that exploit the vulnerabilities. Controls can be applied at the levels of the data, the programs, the system, the physical devices, the communications links, the environment, and the personnel. Sometimes several controls are needed to cover a single vulnerability, and sometimes one control addresses many problems at once.Cryptography - secret writing is the strongest tool for controlling against many kinds of security threats. Well-disguised data cannot be read, modified, or fabricated easily.

2. Objectives:

The students completing this module are expected to understand

The basic ideas of security and its key concepts.

The goals of secure computing

The threats to security in computing

Classical encryption techniques

3. Syllabus

Prerequisites	Syllabus	Duration
OSI model, safety of computing system such as hardware software to avoid interruption, interception, modification & fabrication of data.	Threats, Types, Vulnerabilies, Security Goals-CIA Triad, Attacks, Security Principles, Threat Modelling	7 Hrs

4. Definitions:

NON REPUDIATION: Non repudiation means to ensure that a transferred message has been sent and received by the parties claiming to have sent and received the message. Non repudiation is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message. Non repudiation can be obtained through the use of:

CRYPTOGRAPHY: The art of protecting information by transforming it (encrypting it) into an unreadable format, called cipher text. Only those who possess a secret key can decipher (or decrypt) the message into plain text. Encrypted messages can sometimes be broken by cryptanalysis, also called code breaking, although modern cryptography techniques are virtually unbreakable.

5. Learning:

1. Identify confidentiality, integrity, availability as information security goals.
2. Explain interception, interruption, modification, fabrication as threats.
3. Explain controls available to address these threats: encryption, programming controls, operating systems, network controls, administrative controls, law, and ethics.
4. Classify classical encryption techniques as mono-alphabetic and poly-alphabetic
5. Cryptanalysis: how encryption systems are "broken"

6. Module theory with example and diagram topic wise

6.1 BACKGROUND:

Security Architecture can be defined as the design artifacts that describe how the security controls (security countermeasures) are positioned, and how they relate to the overall information technology architecture. These controls serve the purpose to maintain the system's quality attributes, among them confidentiality, integrity, availability, accountability and assurance.

Two fundamental concepts in computer and information security are the security model, which outlines how security is to be implemented -- in other words, providing a "blueprint" -- and the architecture of a computer system, which fulfills this blueprint. A security policy outlines how data is accessed, what level of security is required and what actions should be taken when these requirements are not met.

Computer and information security covers many areas within an enterprise. Each classical encryption techniques area has security vulnerabilities and, hopefully, some corresponding countermeasures that raise the security level and provide better protection. Not understanding the different areas and security levels of network devices, operating systems, hardware, protocols and applications can cause security vulnerabilities that can affect the environment as a whole.

6.2 Characteristics of Computer Intrusion

Any part of a computing system can be the target of a crime. When we refer to a **computing system**,we mean a collection of hardware, software, storage media, data, and people that an organization uses to perform computing tasks.

Sometimes, we assume that parts of a computing system are not valuable to an outsider, but often we are mistaken. For instance, we tend to think that the most valuable property in a bank is the cash, gold, or silver in the vault. But in fact the customer information in the bank's computer may be far more valuable. Stored on paper, recorded on a storage medium, resident in memory, or transmitted over telephone lines or satellite links, this information can be used in myriad ways to make money illicitly. A competing bank can use this information to steal clients or even to disrupt service and discredit the bank.

Any system is most vulnerable at its weakest point. A robber intent on stealing something from your house will not attempt to penetrate a two-inch-thick metal door if a window gives easier access. Similarly, a sophisticated perimeter physical security system does not compensate for unguarded access by means of a simple telephone line and a modem. We can codify this idea as one of the principles of computer security.

6.2.1 Principle of Easiest Penetration: An intruder must be expected to use any available means of penetration. The penetration may not necessarily be by the most obvious means, nor is it necessarily the one against which the most solid defense has been installed. And it certainly does not have to be the way we want the attacker to behave.

6.3 Attacks

When you test any computer system, one of your jobs is to imagine how the system could malfunction. Then, you improve the system's design so that the system can withstand any of the problems you have identified. In the same way, we analyze a system from a security perspective, thinking about ways in which the system's security can malfunction and diminish the value of its assets.

6.3.1Vulnerabilities, Threats, Attacks, and Controls

A computer-based system has three separate but valuable components: **hardware**, **software,** and **data**. Each of these assets offers value to different members of the community affected by the system. To analyze security, we can brainstorm about the ways in which the system or its information can experience some kind of loss or harm.

A **vulnerability** is a weakness in the security system, for example, in procedures, design, or implementation, that might be exploited to cause loss or harm. For instance, a particular system may be vulnerable to unauthorized data manipulation because the system does not verify a user's identity before allowing data access.

A **threat** to a computing system is a set of circumstances that has the potential to cause loss or harm. To see the difference between a threat and a vulnerability, consider the illustration in Figure 1. Here, a wall is holding water back. The water to the left of the wall is a threat to the man on the right of the wall: The water could rise, overflowing onto the man, or it could stay beneath the height of the wall, causing the wall to collapse. So the threat of harm is the potential for the man to get wet, get hurt, or be drowned. For now, the wall is intact, so the threat to the man is unrealized.

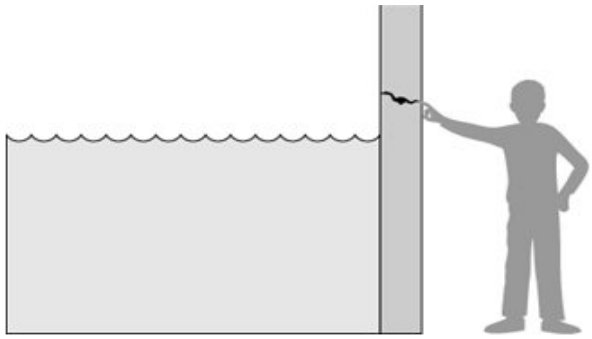

Fig 1 Threats, Controls, and Vulnerabilities.

However, we can see a small crack in the wall vulnerability that threatens the man's security. If the water rises to or beyond the level of the crack, it will exploit the vulnerability and harm the man.

A human who exploits a vulnerability perpetrates an **attack** on the system. An attack can also be launched by another system, as when one system sends an overwhelming set of messages to another, virtually shutting down the second system's ability to function.

A threat is blocked by control of a vulnerability.

6.3.2 System Security Threats

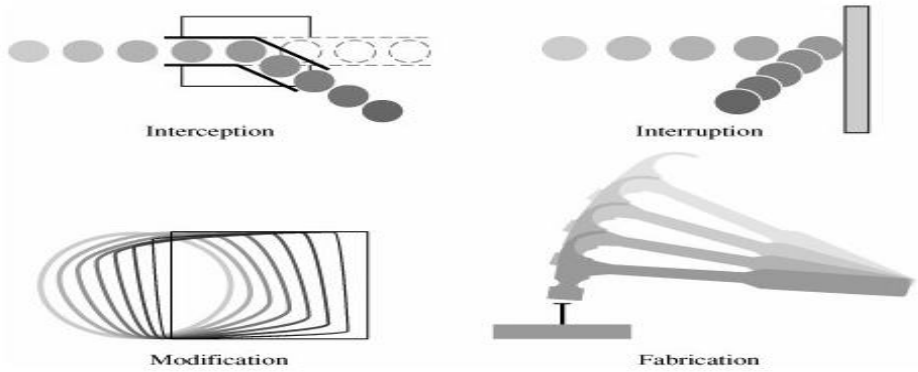

Figure 2. System Security Threats.

- An **interception** means that some unauthorized party has gained access to an asset. The outside party can be a person, a program, or a computing system. Examples of this type of failure are illicit copying of program or data files, or

wiretapping to obtain data in a network. Although a loss may be discovered fairly quickly, a silent interceptor may leave no traces by which the interception can be readily detected.

- In an **interruption**, an asset of the system becomes lost, unavailable, or unusable. An example is malicious destruction of a hardware device, erasure of a program or data file, or malfunction of an operating system file manager so that it cannot find a particular disk file.
- If an unauthorized party not only accesses but tampers with an asset, the threat is a **modification**. For example, someone might change the values in a database, alter a program so that it performs an additional computation, or modify data being transmitted electronically. It is even possible to modify hardware. Some cases of modification can be detected with simple measures, but other, more subtle, changes may be almost impossible to detect.
- Finally, an unauthorized party might create a **fabrication** of counterfeit objects on a computing system. The intruder may insert spurious transactions to a network communication system or add records to an existing database. Sometimes these additions can be detected as forgeries, but if skillfully done, they are virtually indistinguishable from the real thing.

These four classes of threats -interception, interruption, modification, and fabrication describe the kinds of problems we might encounter.

Method, Opportunity, and Motive

A malicious attacker must have three things:

- **Method** *:* the skills, knowledge, tools, and other things with which to be able to pull off the attack
- **Opportunity** *:* the time and access to accomplish the attack
- **Motive** *:* a reason to want to perform this attack attack against this system

6.4 Security Goals

When we talk about computer security, we mean that we are addressing three important aspects of any computer-related system: **confidentiality**, **integrity,** and **availability.**

- Confidentiality ensures that computer-related assets are accessed only by authorized parties. That is, only those who should have access to something will actually get that access. By "access," we mean not only reading but also viewing, printing, or simply knowing that a particular asset exists. Confidentiality is sometimes called **secrecy** or **privacy**.

- Integrity means that assets can be modified only by authorized parties or only in authorized ways. In this context, modification includes writing, changing, changing status, deleting, and creating.
- Availability means that assets are accessible to authorized parties at appropriate times. In other words, if some person or system has legitimate access to a particular set of objects, that access should not be prevented. For this reason, availability is sometimes known by its opposite, denial of service.
-

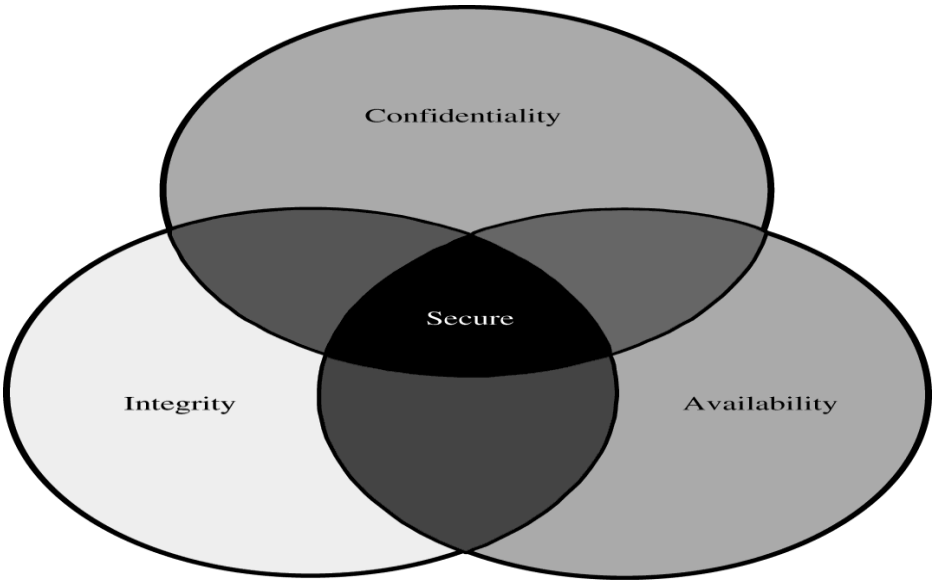

Fig- 3 Relationship between confidentiality, integrity and availability

Security in computing addresses these three goals. One of the challenges in building a secure system is finding the right balance among the goals, which often conflict. For example, it is easy to preserve a particular object's confidentiality in a secure system simply by preventing everyone from reading that object. However, this system is not secure, because it does not meet the requirement of availability for proper access. That is, there must be a balance between confidentiality and availability.

6.5 Methods of Defense

Harm occurs when a threat is realized against a vulnerability. To protect against harm, then, we can neutralize the threat, close the vulnerability, or both. The possibility for harm to occur is called risk. We can deal with harm in several ways. We can seek to

- **prevent it**, by blocking the attack or closing the vulnerability

- **deter it**, by making the attack harder but not impossible
- **deflect it**, by making another target more attractive (or this one less so)
- **detect it**, either as it happens or sometime after the fact
- **recover** from its effects

6.6 Controls

In Computer security we have many controls at our disposal. Some are easier than others to use or implement. Some are cheaper than others to use or implement. And some are more difficult than others for intruders to override.

We use one or more controls, according to what we are protecting, how the cost of protection compares with the risk of loss, and how hard we think intruders will work to get what they want.

6.6.1 Encryption

Encryption is the formal name for the scrambling process. We take data in their normal, unscrambled state, called cleartext, and transform them so that they are unintelligible to the outside observer; the transformed data are called enciphered text or ciphertext. Using encryption, security professionals can virtually nullify the value of an interception and the possibility of effective modification or fabrication

6.6 .2 Software Controls

Programs must be secure enough to prevent outside attack. They must also be developed and maintained so that we can be confident of the programs' dependability.

Program controls include the following:

- internal program controls: parts of the program that enforce security restrictions, such as access limitations in a database management program
- operating system and network system controls: limitations enforced by the operating system or network to protect each user from all other users
- independent control programs: application programs, such as password checkers, intrusion detection utilities, or virus scanners, that protect against certain types of vulnerabilities
- development controls: quality standards under which a program is designed, coded, tested, and maintained to prevent software faults from becoming exploitable vulnerabilities

We can implement software controls by using tools and techniques such as hardware components, encryption, or information gathering. Software controls frequently affect users directly, such as when the user is interrupted and asked for a password before being given access to a program or data.

6.6 .3 Hardware Controls

Numerous hardware devices have been created to assist in providing computer security. These devices include a variety of means, such as

- hardware or smart card implementations of encryption
- locks or cables limiting access or deterring theft
- devices to verify users' identities
- firewalls
- intrusion detection systems
- circuit boards that control access to storage media

6.6 .4 Policies and Procedures

Sometimes, we can rely on agreed-on procedures or policies among users rather than enforcing security through hardware or software means. In fact, some of the simplest controls, such as frequent changes of passwords, can be achieved at essentially no cost but with tremendous effect. Training and administration follow immediately after establishment of policies, to reinforce the importance of security policy and to ensure their proper use.

6.6 .5 Physical Controls

Some of the easiest, most effective, and least expensive controls are physical controls. Physical controls include locks on doors, guards at entry points, backup copies of important software and data, and physical site planning that reduces the risk of natural disasters. Often the simple physical controls are overlooked while we seek more sophisticated approaches.

6.7 Effectiveness of Controls

Merely having controls does no good unless they are used properly. Let us consider several aspects that can enhance the effectiveness of controls.

Awareness of Problem

People using controls must be convinced of the need for security. That is, people will willingly cooperate with security requirements only if they understand why security is appropriate in a given situation. However, many users are unaware of the need for security, especially in situations in which a group has recently undertaken a computing task that was previously performed with lax or no apparent security.

Likelihood of Use

Of course, no control is effective unless it is used. The lock on a computer room door does no good if people block the door open.

Principle of Effectiveness: Controls must be usedand used properlyto be effective. They must be efficient, easy to use, and appropriate.

This principle implies that computer security controls must be efficient enough, in terms of time, memory space, human activity, or other resources used, that using the control does not seriously affect the task being protected. Controls should be selective so that they do not exclude legitimate accesses

7. Objective Questions:

1. Message _____ means that the sender and the receiver expect privacy.

    a. Confidentiality
    b. Integrity
    c. Authentication
    d. None Of The Above

2. Message_____ means that the data must arrive at the receiver exactly as sent.

    a. Confidentiality
    b. Integrity
    c. Authentication
    d. None Of The Above

3. Message _____ means that the receiver is ensured that the message is coming from the intended sender, not an imposter.

    a. Confidentiality
    b. Integrity
    c. Authentication
    d. None of the above

4. _____ means that a sender must not be able to deny sending a message that he sent.

    a. Confidentiality
    b. Integrity
    c. Authentication
    d. Non repudiation

5. _____ means to prove the identity of the entity that tries to access the system's resources.

    a. Message authentication
    b. Entity authentication
    c. Message confidentiality
    d. None of the above

6. A (n) _____ can be used to preserve the integrity of a document or a message.

a. Message Digest
b. Message Summary
c. Encrypted Message
d. None of the above

7._____ text is that which cannot be read unless a special password or key is put in to decode it.

a. Encrypted
b. Decrypted
c. Cipher
d. Plain

8._____ (sometimes called clear text) is the data that exists before any encryption has been performed.

a. Plain text
b. Cipher text
c. Password
d. Secret

9. Computer security means that we are addressing

a. Confidentiality
b. integrity,
c. availability.
d. all the above

10. Availability is sometimes known by its opposite,_____ .

ANSWERS:

1. (A)	2. (B)	3. (C)	4. (D)	5. (B)	6. (C)	7. (C)
8. (A)	9. (D)	10.denial of service.				

8. Subjective Questions:

1. Compare threat and vulnerability.

2. Explain the possible system security threats in a computing system.

3. Write a short note on “Security Goals”.

4. What are the various types of the vulnerabilities of computing systems?

5. What are the various controls or counter measures that attempt to prevent exploiting a computing system?

6. Explain different methods of defense.

7. Explain the methods used to enhance the effectiveness of controls in Computing systems.

10. References

1. William Stallings ,Computer Security Principles and Practice, , Pearson Education.
2. Mark Stamp’s Information Security Principles and Practice, Wiley
3. Charles P. Pfleeger, Security in Computing, Pearson Education ,4th Edition.
4. Behrouz A. Ferouzan, “Cryptography & Network Security”, Tata Mc Graw Hill